PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Sécurité sous Debian 13

06-720 PSE 25-27 5-14 Linux - La sécurité sous Debian 13 (partie 1) — source : fiche de révision du module (gemma4, 03/11/2026)

À RETENIR

1. Le risque résulte d'une menace exploitant une vulnérabilité, pondérée par sa probabilité et la gravité de l'impact sur le DICP.
2. La sécurité technique doit être complétée par des aspects organisationnels, humains, physiques et juridiques pour être efficace.
3. L'usage des capabilities est une alternative plus fine au bit SUID root car il permet d'accorder un privilège précis.

Fondamentaux de la sécurité

Notion	À retenir
Critères DICP	**Disponibilité** (accès), **Intégrité** (non-altération), **Confidentialité** (accès limité), **Preuve** (traçabilité horodatée/non répudiable).
Aspects sécurité	Approche multidimensionnelle : **organisationnel**, **technique**, **humain**, **physique** et **juridique/réglementaire**.
Analyse risque	Risque = **menace** exploitant une **vulnérabilité**, pondérée par sa **probabilité** et la **gravité** de l'impact sur le **DICP**.

Synthèse des secteurs de la sécurité

Notion	À retenir
Sécurité physique, système et réseau	Protection des locaux (**vidéosurveillance**, **incendie**), socle via **PAM** et **noyau**, et réseau via **nftables**, **RADIUS**, `sysctl` ou `fail2ban`.
Sécurité applicative et des données	Logiciels via **chroot**, **capabilities**, **AppArmor** ; données via chiffrement et sauvegarde (**règle 3 2 1** ou **3 2 1 1 0** avec copie **immuable**).
Sécurité organisationnelle, humaine et juridique	Procédures (**RSSI**), sensibilisation (**charte informatique**), conformité **RGPD** et **Code de la défense** (cryptologie via **ANSSI**).

Synthèse des mesures de protection

Notion	À retenir
Sauvegarde 3 2 1	Conserver **3 copies**, sur **2 supports** différents, dont **1 copie externalisée** hors site. Version **3 2 1 1 0** : ajoute **1 copie hors ligne immuable** et **0 erreur** de restauration.
Partitionnement	Séparer `/boot`, `/tmp`, `/var`, `/var/log` et `/home`. Utiliser **LVM** en production. Options : `nosuid`, `nodev`, `noexec` (attention sur `/tmp`). Attributs : `chattr +i` (immuabilité) ou `chattr +a` (ajout seul).
Mises à jour	Contre les **CVE**. Debian utilise les **DSA** et un dépôt **security** (Trixie). Outils : `unattended-upgrades` (automatisation) et `debsecan` (signalement). Correctifs critiques : idéalement sous **30 jours**.

Synthèse du contrôle des accès

Notion	À retenir
Infrastructure PAM	Découple les applications via des modules dans `/etc/pam.d/`. Verrouillage via `pam_faillock.so` (`deny=5`, `unlock_time=900`).
Mots de passe et SSH	Hachage `yescrypt` (`$y`) dans `/etc/shadow`. Robustesse via `libpam-pwquality` (min **12** caractères). Clés SSH `ed25519` recommandées.
RADIUS et AAA	Principe **AAA** (Authentication, Authorization, Accounting). Implémentation `FreeRADIUS`. Sécurité par **secret partagé** robuste et unique par équipement.

Résumé de la sécurité réseau

Notion	À retenir
Filtrage nftables/fail2ban	Utiliser `nftables` (référence Debian 13) avec un jeu de règles rejetant par défaut tout flux entrant. `fail2ban` bannit dynamiquement via `nftables` les IP après échecs d'authentification.
Segmentation et chiffrement	Limiter la propagation via **VLAN** ou **DMZ** (pas d'accès direct non filtré vers l'interne). Proscrire **Telnet**, **FTP**, **HTTP** ; privilégier **SSH**, **SFTP**, **HTTPS**, **SNMPv3**.
Durcissement sysctl	Ajuster les paramètres via `sysctl --system`. Désactiver **routage IP**, **redirections ICMP**, **source routing**. Activer **SYN cookies** et journaliser les **martians**.

Résumé de la traçabilité et du cloisonnement

Notion	À retenir
Journalisation	**journald** centralise via `systemd` ; `journalctl` consulte les services ; créer `/var/log/journal` pour la **persistance**. **auditd** (audit du noyau) surveille fichiers et appels système via `auditctl` et `ausearch`.
Comptabilité et connexions	**acct** trace l'exécution des commandes (`lastcomm`). **Connexions** : `last` (`/var/log/wtmp`), `lastb` (échecs, `/var/log/btmp`) et `lastlog` (dernière connexion par utilisateur).
Mécanisme chroot	Modifie la **racine apparente** pour isoler des services (DNS, FTP, SFTP) via `debootstrap` et `chroot`. **Limites** : ne cloisonne ni processus, ni réseau, ni utilisateurs ; **pas une véritable isolation**.

Synthèse de la gestion avancée des droits

Notion	À retenir
Droits étendus, ACL et capabilities	Modèle Unix (**SUID**, **SGID**, **sticky bit**), **ACL POSIX** via `setfacl`, attributs via `chattr`/`lsattr` (immuabilité) et **capabilities** pour privilèges précis (ex: port **< 1024**).
Contrôle d'accès obligatoire avec AppArmor	Mécanisme intégré depuis **Debian 10**. Associe des profils à des binaires. Commandes : `aa-status` (consulter) et `aa-enforce` (mode strict). S'applique **indépendamment** des droits utilisateur.
Politique de sécurité PSSI et référentiels historiques	La **PSSI** lie enjeux et technique. Méthode **EBIOS Risk Manager** (ANSSI). Référentiel **Orange Book** (1983, DoD USA) : introduit le contrôle d'accès obligatoire (dès la **classe B1** ; classes **D** à **A1**) et ouvert la voie aux **Critères Communs**.

Pièges et confusions

- ⚠ Confondre la vulnérabilité (faiblesse) avec la menace (événement susceptible de l'exploiter).
- ⚠ Croire que la sécurité technique est suffisante sans les aspects organisationnels, humains, physiques et juridiques.
- ⚠ Considérer le mécanisme chroot comme une véritable sandbox de sécurité.
- ⚠ Oublier qu'un processus avec les privilèges root à l'intérieur d'un chroot peut potentiellement en sortir.
- ⚠ Penser qu'une sauvegarde a une valeur réelle sans une restauration régulièrement testée et documentée.

Sigles et définitions

DICP critères de disponibilité, intégrité, confidentialité et preuve servant de grille de lecture à toute analyse de risque

RGPD règlement relatif à la protection des données à caractère personnel imposant des obligations de conformité

ANSSI Agence nationale de la sécurité des systèmes d'information, organisme compétent pour la réglementation de la cryptographie en France

PSSI politique de sécurité des systèmes d'information qui formalise les objectifs, les règles et les responsabilités d'une organisation

AAA principes d'authentification, d'autorisation et de comptabilité utilisés par le protocole RADIUS

CVE vulnérabilités connues répertoriées pour permettre le maintien à jour des logiciels

MAC contrôle d'accès obligatoire permettant d'imposer une politique de sécurité indépendamment de la volonté du propriétaire d'un fichier

SUID bit spécial du modèle Unix permettant à un binaire de s'exécuter avec les droits de son propriétaire

Auto-test

1. Quels sont les quatre critères de la grille DICP ?
2. Quelle règle de sauvegarde ajoute une copie hors ligne immuable et 0 erreur de restauration ?
3. Quel outil permet de surveiller les fichiers et les appels système via le noyau ?
4. Quel est l'avantage des capabilities par rapport au bit SUID root ?
5. Quelle commande permet de consulter l'état d'AppArmor ?

Réponses : **1.** Disponibilité, intégrité, confidentialité et preuve. · **2.** La règle 3 2 1 0. · **3.** auditd. · **4.** Elles permettent d'accorder un privilège précis au lieu de l'intégralité des droits du propriétaire. · **5.** aa-status.

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.